W3WI_SE411 - Forschungsseminar Informatik / Advanced Practical IT Security

Dozent: Prof. Dr. Michael Eichberg
Kontakt: michael.eichberg@dhbw-mannheim.de , Raum 149B
Unterlagen: Moodle
Version: 24SEA - 2026-10-29

Teaser

In dieser Veranstaltung werden wir uns mit den Grundlagen praktischer Angriffe und Verteidigungsmaßnahmen im Bereich IT Security auseinandersetzen. Wir werden uns der Frage widmen, wie, wann und in welcher Form man - auf den ersten Blick abgesicherte Systeme/geschützte Daten - einerseits angreifen (🇺🇸 *to exploit*) kann und andererseits wie man die Sicherheit weiter erhöhen kann.

Wir werden uns in diesem und dem nächsten Semester ausgewählten Themen widmen, die von der Sicherheit von Passwörtern und Angriffen auf selbige bis hin zu der Sicherheit von Netzwerken und Webanwendungen reichen.

Wir werden uns somit auf praktische Aspekte der IT Sicherheit fokussieren. Theoretische Grundlagen sind nur insoweit relevant, dass sie in der Praxis eine Relevanz haben.

Hinweis

Für diese Veranstaltung sind Grundkenntnisse in Linux/Unix/MacOS hilfreich, aber nicht notwendig. Notwendig ist aber Interesse an tiefer gehenden technischen Details.

Es wird empfohlen sich eine virtuelle Maschine (z. B. mit VirtualBox oder UTM) aufzusetzen, auf der Sie Linux (ganz insbesondere z. B. Kali Linux) oder ggf. Mac OS installieren. Auf eigene Gefahr hin können Sie auch WSL2 unter Windows verwenden. Mac User können viele der Tools direkt installieren oder über Homebrew bzw. MacPorts beziehen.

Eine Installation in einer VM ist aber immer empfohlen.

Grober Ablauf

- 1. Semester: 6 Termine; (50% der Endnote - d. h. 60 von 120 Punkten)
- 2. Semester: 5 Termine (50% der Endnote - d. h. 60 von 120 Punkten)

1. Erstes Semester: Passwortwiederherstellung und Reverse-Engineering

Ablauf - 1. Semester - Passwortwiederherstellung

28. August: *Einführung in Passwortwiederherstellung*

4. September: Begleitung bei der Bearbeitung von Übungen

7. September: **Bewertetes Lab (max. 30 Punkte)** zum Thema Passwortwiederherstellung

> ▲ Achtung!
>
> Sollten Sie an diesem Tag verhindert sein, dann ist ein offizieller Prüfungsrücktritt erforderlich!

Ablauf - 1. Semester - Reverse Engineering

11. September:
- *Einführung in Reverse Engineering*
- Zusammenfinden in 2er Teams zur Bearbeitung der Portfolioaufgabe
- Ausgaben von Übungsaufgaben

18. September: Beantwortung von Fragen/Unterstützung bei der Erstellung von Artefakten

2. Oktober: **Abgabe der gehärteten Programme (max. 15 Punkte)**

12. Oktober: **Bewertetes Lab (max. 15 Punkte)**

> ▲ Achtung!
>
> Sollten Sie an diesem Tag verhindert sein, dann ist ein offizieller Prüfungs-rücktritt erforderlich!

Inhalte

Hinweis

Diese Veranstaltung ist ergänzend zur Veranstaltung SE III IT-Sicherheit zu sehen. D. h. Inhalte, die dort vermittelt werden, werden hier nicht noch einmal behandelt, sind aber potentiell relevant.

Notenzusammenstellung - 1. Semester - Passwortwiederherstellung

30 Punkte - Aufteilung:

8 Punkte: (ein bis zwei) Prüfungsgespräche zu Ihrem Vorgehen/Lösungsweg/Herausforderungen mit insgesamt ca. 8 Minuten Dauer.
Sie müssen zeigen, dass Sie verstehen, was sie tun und warum Sie es tun. Sie müssen in der Lage sein, zu argumentieren, wie sie verwandte Probleme angehen würden.

22 Punkte: Bearbeitung der Aufgaben. Zu den Aufgaben wird es Fragen geben. Am Ende des Tages können Sie diese dann einreichen.

Notenzusammenstellung - 1. Semester - Reverse Engineering (RE)

15 Punkte: Erstellen einer auf Linux lauffähigen Anwendung, die RE erschwert.

Anforderungen:

- Die Anwendung muss unter Ubuntu Linux 26.04 (x86-64) lauffähig sein (Kommandozeile) und folgendermaßen vorliegen:
  - Binary (`.elf` Datei)
  - ausführbares Java Archive (`java -jar <Anwendung.jar>`) (Java 26)
  - Python (`.py` Datei) (Python 3.14)
  - Webanwendung, die serverseitig nur Node.js (Node 24) und Express.js verwendet und clientseitig keine Bibliotheken verlangt.

    In diesem Falle muss das clientseitig JavaScript geschützt sein und der Server muss mit einem Befehl (z.B. npm run) startbar sein.
- Das erfolgreiche Reverse Engineering soll es einem ermöglichen einen Schutzmechanismus zu umgehen (Capture-the-Flag (CTF)).

  Beispiele:
  - einen Verschlüsselungsalgorithmus aushebeln
  - ein Secret zu extrahieren
  - ein ...
- Der Aufwand für ein erfolgreiches Reverse Engineering sollte - inkl. KI Unterstützung - ca. 90 Minuten betragen.

Abgaben:

- [7P] Die Anwendung inkl. aller Sourcen und Build-Scripte (QS ist nicht notwendig)
- [1P] Eine Nutzerdokumentation, die beschreibt, was die Anwendung tut (ggf. einfach die Hilfe, die auf der Kommandozeile ausgegeben wird)
- [5P] Eine eigene Dokumentation, die genau beschreibt, wo das Sicherheitsproblem liegt und wie man diese reversen kann. Diesbezüglich sind alle zu verwendenden Scripte und Tools genauestens anzugeben. Die Anleitung muss es erlauben die für das RE notwendigen Schritte direkt nachvollziehbar zu machen.
- [2P] Eine qualifizierte Einschätzung wie gut Ihr Schutzmechanismus eine KI davon abhält die Anwendung zu reversen und das zugrundeliegende Sicherheitsproblem zu identifizieren. Beschreiben Sie ggf. genau welche Tools (Harness) die KI ggf. benötigt.

15 Punkte:

Teil 1: [7P] Lösen einer RE Aufgabe im Team
Die Aufgaben stammen aus den Einreichungen vom 2. Oktober, sofern diese sich dafür eignen; andernfalls stelle ich eigene Aufgaben. Sie bearbeiten in keinem Fall Ihre eigene Einreichung.

(120 Minuten inkl. Lösungsbeschreibung - dann Abgabe.)

Teil 2: [8P] 10-minütige mündliche Prüfungsgespräche mit jedem Team ab 11:45 Uhr.
Gegenstand sind ggf. beide Teile: Ihre am 2. Oktober abgegebene Anwendung und Ihre heutige Lösung. Jedes Teammitglied muss zu beidem sprechfähig sein.

- Gruppe 1: 11:45
- Gruppe 2: 12:00
- Gruppe 3: 12:15
- Gruppe 4: 12:30
- Gruppe 5: 12:45

Mittagspause

- Gruppe 6: 13:30
- Gruppe 7: 13:45
- Gruppe 8: 14:00
- Gruppe 9: 14:15
- Gruppe 10: 14:30
- Gruppe 11: 14:45
- Gruppe 12: 15:00
- Gruppe 13: 15:15

Teamzuteilung

Gruppe 1:
Lorenzo Negri & Adrian Polzer

Gruppe 2:
Victor Hacker & Till Burdorf

Gruppe 3:
Kevin Becker & Jonas Thaddey

Gruppe 4:
Ajun Anpalakan & Katrin Seeberg

Gruppe 5:
Luis Heider & Daniel Brecht

Gruppe 6:
Wanisa Nassery & Leonie Berens

Gruppe 7:
Jannis Voß & Michelle Ingerl

Gruppe 8:
Erel Acmi & Andre Maxinger

Gruppe 9:
Sebastian Rudolph & Fabian Luers

Gruppe 10:
Nico Becker & Christina Schultz

Gruppe 11:
Lea Dennhardt & Max Rommel

Gruppe 12:
Lukas Gröning & Nhi Duong

Gruppe 13:

Jessica Limmer & Erik Breuer

2. Zweites Semester: Pentesting von Webanwendungen

Grober Ablauf - 2. Semester

1. Einführung in Pentesting
2. Studentische Präsentationen zur Vertiefung bzw. Betrachtung wichtiger Aspekte.
3. Aufgaben für die entsprechende Fragestellung.
4. Prüfungsgespräch zu Ihren Ergebnissen

Ablauf

19.02.2027:
- Ausgabe der Präsentationsthemen
- Kurze Einführung in das Thema Pentesting

01.03.2027:
- Bearbeitung der Präsentationsthemen mit dem Ziel „Hands-on“
- Ich stehe für Rückfragen *online* zur Verfügung

> ▲ Achtung!
>
> https://bbb.dhbw.de/mannheim/eic-uue-f52-6xb

8.03.2027:
- Halten der Präsentationen (langer Termin)
- Ausgabe der Aufgaben

30.03.2027:
- Bearbeitung der Pentestingaufgaben
- Ich stehe für Rückfragen *online* zur Verfügung

> ▲ Achtung!
>
> https://bbb.dhbw.de/mannheim/eic-uue-f52-6xb

20.04.2027:
- Prüfungsgespräche

Vortragsthemen - Grundlagen

Dauer pro Person: 10 Minuten

- [1 Person] Grenzen der Multi-Faktor-Authentifizierung

  (MFA fatigue, Token Theft, ...)
- [1 Person] Shodan and OSINT im Pentesting
- [1 Person] Server-Side Request Forgery (Portswigger - SSRF)

  (Ggf. inkl. Demonstration und Erklärung wie man sich schützt.)
- [2 Personen] MITRE ATT&CK

  (Knowledge base of adversary tactics and techniques based on real-world observations.)
  1. Person - allgemeine Einführung
  2. Person - Darstellung ausgewählter Themen

  (Bitte darauf achten, dass es mit den OWASP Vorträgen zu keinen relevanten Überschneidungen kommt.)
- [1 Person] OWASP Web Security Testing Guide
- [1 Person] OWASP Mobile Application Security
- [1 Person] Copy Fail (https://copy.fail) (case study)

  Als Case-study aufarbeiten und auch die Entstehungsgeschichte erklären. Bitte auch in Relation zu den entsprechenden klassischen Sicherheitsprinzipien von Saltzer und Schroeder (1975) setzen.
- [1 Person] Scapy

  (Interactive packet manipulation library)

  Eine Demo ist sehr wünschenswert.
- [1 Person] OpenVAS - Community Edition (Scanner)

  (Vulnerability Testing)

  Achtung: bei der Community Edition handelt es sich wohl um ein „rohes Produkt".
- [2 Personen] OWASP Top Ten 2025 (z. B. 1. Person Lücke 1-5; 2. Person Lücke 6 - 10; die konkrete Einteilung ist aber freigestellt!)

  Jeweils mit konkreten Beispielen in etablierten Sprachen/Frameworks.
- [2 Personen] OWASP Top Ten for LLM Applications (z. B. 1. Person Lücke 1-5; 2. Person Lücke 6 - 10; die konkrete Einteilung ist aber freigestellt!)
- [1 Person] Wireshark für Pentester

  Fokus auf: typische Filter, Credentials finden, verdächtige Muster
- [1 Person] Gobuster

  (A directory/file, DNS and virtual host brute-forcing tool)

Vortragsthemen - Angewandt

Dauer pro Person: 15 Minuten

> ▲ Achtung!
>
> Niemand, der eines der folgenden Themen bearbeitet, darf mit jemand anderem aus dieser Gruppe bei der Bearbeitung der Portfolioaufgabe zusammenarbeiten.

- [1 Person] Nmap (und ncat)

  (Network discovery and security auditing.)
- [2 Personen] Zed Attack Proxy (ZAP)

  (Wep App Scanner)

  1. Einführung (inkl. Marketplace)
  2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführen und dann ZAP demonstrieren!)
- [2 Personen] Burp Suite

  (Penetration testing toolkit.)

  1. Einführung (inkl. Marketplace)
  2. Live Demo basierend auf einer Webanwendung (bitte erst in die Anwendung und die Lücken einführen und dann Burp Suite demonstrieren!)
- [2 Personen] Metasploit (Open Source)

  (Penetration testing framework.)

  1. Einführung in Metasploit - d. h. Architektur und Aufbau von Metasploit
  2. Live Demo (bitte erst in das Szenario einführen)
- [1 Person] Nikto

  (Open-source web server scanner checking for dangerous or interesting files and programs, identifying outdated versions of servers and components, detecting common server misconfigurations such as multiple index files, HTTP server options, and more.)

Themenverteilung

Nr.	Thema	#Stud.	1. Student	2. Student
1.	MFA	1		
2.	OSINT	1		
3.	SSRF	1		
4.	ATT&CK	2		
5.	OWASP - WSTG	1		
6.	OWASP - MAS	1		
7.	Gobuster	1		
8.	Scapy	1		
9.	OpenVAS	1		
10.	OWASP Top Ten	2		
11.	OWASP Top Ten for LLM Apps	2		
12.	Wireshark	1		
13.	Copy Fail	1		
14.	Nmap	1		
15.	ZAP	2		
16.	Burp	2		
17.	Metasploit	2		
18.	Nikto	1		

Bewertungskriterien

Für die Präsentation Ihres Fachvortrags

- Hinweise für Präsentationen
- Notenanteil: 25% von der Gesamtnote - d.h. 30 Punkte:
  - 29 Punkte für den Vortrag

    Der Vortrag muss am Tag der Präsentation bis spätestens 7:00 Uhr hochgeladen sein.

    Für die Teile, die sie demonstrieren, laden Sie bitte eine ausreichende Anzahl an Screenshots (in einem PDF) hoch, damit nachvollzogen werden kann, was demonstriert wurde; alternativ können Sie einen Screencast Ihrer Demo erstellen und diesen *direkt* nach Ihrem Vortrag hochladen.
  - 1 Punkt für das Ausfüllen, Gegenzeichnen und zeitgerechte Hochladen der Checkliste

    Bei Gruppenarbeit hat dies jeder Studierende eigenständig zu machen; es erfolgt keine Abgabe der Checkliste für die Gruppe.

Für die mündliche Prüfung (X.Y.2027 - Raum 261C)

- Anzahl und Art der gefundenen Schwachstellen

  Fertigen Sie ein Dokument (.md, .pdf) an, dass Sie vorher (siehe Moodle) hochladen und in dem Sie die Lücken kurz dokumentieren. Pro Lücke dokumentieren Sie den Server + die Anwendung/den API Endpunkt/... der Vulnerabel ist und mit welchem CWE die Lücke verknüpft ist. Sollte Sie kein CWE finden, dann schreiben Sie ein/zwei Sätze, um die Lücke zu charakterisieren.

  > ▲ Achtung!
  >
  > Eine detaillierte Dokumentation ist nicht erforderlich, da es sich im Wesentlichen um ein Prüfungsgespräch handelt. Es geht hier ausschließlich um eine knappe Auflistung der Lücken! Eine Beschreibung der Lücken oder wie diese gefixt werden könnten ist nicht gewünscht.
  >
  > Der Einsatz von KI zur Erstellung/Verbesserung der Liste ist strikt untersagt.

  Wir werden diese Liste als Start für das Prüfungsgespräch verwenden.
- Demonstration der Schwachstellen

  Bringen Sie (mind.) einen Rechner mit, auf dem Sie alle Tools etc. installiert haben, und mit dem Sie in der Lage sind die Lücke unmittelbar zu demonstrieren.

  Das Anlegen von (kleineren) Scripten ist ggf. empfohlen.
- Beantwortung von Fragen

  Jeder muss zu jeder Lücke sprechfähig sein.
- Notenanteil: 25% von der Gesamtnote - d. h. 30 Punkte:
- Dauer: ca. 25 Minuten pro Gruppe

Teilnahme am Pentest

Laden Sie bis zum X.Y.2027 7:00 Uhr, Ihre Bestätigung der Teilnahmebedingungen hoch.

Gruppenzuteilung Pentesting

Datum: 20.04.2027

Ort: 261 C

#	Uhrzeit	1. Stud.	2. Stud.	3. Stud.
1	8:30	X	Y	Z
2	9:10	X	Y	Z
3	9:50	X	Y	Z
4	10:30	X	Y	Z
5	11:10	X	Y	Z
6	13:30	X	Y	Z
7	14:10	X	Y	Z
8	14:50	X	Y	Z

Pentesting

Die folgenden Server dürfen Sie einem Pentest unterziehen:

Server	Komplexität
141.72.13.218	*
141.72.12.145	**
141.72.12.138 *four-wins.michael-eichberg-at-dhbw-de.users.dhbw.site*	**
141.72.176.151 **(ab 4. Juli)**	* _ **
141.72.12.141 *quizzy.michael-eichberg-at-dhbw-de.users.dhbw.site*	***

Ⓛ Legende

* = einfach; *** = sehr schwer

⊘ !GEFAHR!

Unter keinen Umständen dürfen Sie andere als die hier gelisteten Server *angreifen*. Scans von Subdomänen (es gibt auch keine) oder anderen IP-Adressen sind untersagt.

Sie dürfen auch immer nur die hier beschriebenen Angriffe/Änderungen vornehmen. Jegliche darüber hinausgehenden Tätigkeiten sind untersagt.

※ Hinweis

Pentesting der VMs ist nur aus dem Netz der DHBW heraus möglich. D. h. nur wenn Sie eine IP-Adresse im Bereich 141.72.0.0/16 haben. Nutzen Sie eine VM auf OpenStack, dann stellen Sie sicher, dass diese VM keine Egress-Filterung vornimmt und im richtigen Netz ist (ggf. in den Security-Policies zu konfigurieren). Wenn Sie sich per VPN verbinden, dann sollte dies immer der Fall sein.

Pentesting - Rahmenbedingungen

Was ist erlaubt/was nicht...

- Metasploit ist nicht zu verwenden, erfolgreiche Angriffe mit Metasploit werden nicht anerkannt.
- Horizontale Privilegienerweiterungen, sind nicht prüfungsrelevant.
- Alle Sicherheitslücken, die ggf. direkt auf die Verwendung von HTTP zurückzuführen sind, sind zu ignorieren!
- Sollten Sie ggf. auf Informationen über Nutzeraccounts stoßen oder selbige angreifen wollen, dann **nehmen Sie den Nutzeraccount/Gruppenaccount, der zu Ihrer Gruppennummer gehört**.
- Möchten Sie auf einem Server Daten ablegen, dann legen Sie diese auf jeden Fall **nur** in dem Verzeichnis ab, der zu Ihrer Gruppennummer passt! (/home/gruppe<N>, /home/group<N>, ...)
- Sollten Sie Zugriff auf einen Server bekommen - sei es als normaler Nutzer oder als Root-Nutzer - dann dürfen Sie sich auf jeden Fall frei umsehen.
- Die Server haben ggf. viele Schwachstellen; die aber bei Weitem nicht alle gleich einfach auszunutzen sind; suchen Sie die einfachste!
- Bei den Webanwendungen sollten Sie versuchen, so viele verschiedene Schwachstellen wie möglich zu finden. Mappen Sie Ihre Schwachstelle auch immer auf eine CWE! Schwachstellen, den immer nur dieselbe CWE zugrunde liegt, wird nur als eine Schwachstelle gewertet.
- Bei allen Aktionen bedenken Sie, dass auch andere Personen an dem Pentest teilnehmen und eine Einschränkung anderer Personen nicht gestattet ist.
- Sie dürfen keine Maßnahmen durchführen, die die Verfügbarkeiten der Server dramatisch einschränken.
- Sie dürfen unter keinen Umständen Veränderungen oder Aktualisierungen an den Servereinstellungen vornehmen, sollten Sie auf einem oder mehreren Servern Root-Access erlangen!
- Die Struktur von Datenbanken (`alter ...`) darf nicht verändert werden; semantisch sinnvolle Datensätze, um zum Beispiel die Privilegien eines Nutzers zu erweitern, dürfen hinzugefügt werden (`update...`). Daten, die zur Anwendungslogik gehören, dürfen nicht gelöscht werden!
- Untersagt sind darüber hinaus sämtliche Handlungen, die ein verständiger Teilnehmer bei objektiver Betrachtung als nicht vom Zweck der Veranstaltung gedeckt erkennen muss — unabhängig davon, ob sie in diesen Bedingungen ausdrücklich aufgeführt sind. Die vorstehenden Verbote sind beispielhaft, nicht abschließend zu verstehen.

◆ Bemerkung

Sollten Sie auf Probleme stoßen, dann melden Sie sich bitte sowohl **bei Herrn Rutesic** als auch bei mir per Mail.

⚠ Warnung

Für eine Teilnahme an dem Pentest ist die Gegenzeichnung bis zum 3. Juli 2026 7:00 Uhr erforderlich und *persönlich* im Moodle hochzuladen.

Datum: _____ Unterschrift: _____